

Here is the updated detailed flow explanation. This version explicitly highlights the security check with **Ciam**, ensuring the vendor understands that the "Bridge" is backed by a real-time validation against the Bank's central Identity Provider.

Detailed Flow Explanation for Vendor (Updated)

Phase 1: The SAML Bridge (Bootstrapping the Session)

The goal of this phase is to securely translate the user's active Native App session (managed by Ciam) into a Web Session for Marstone (managed by Auth0).

1. **Bridge Request:** The Native App sends a request to the Bank Backend to launch Marstone. Crucially, this request includes the user's current **Ciam Access Token** (or ID Token).
2. **Ciam Validation (Internal Security Check):**
 - The Bank Backend receives the token and performs an API call to **Ciam** (e.g., /introspect) to verify the token is valid, active, and belongs to the expected user.
 - *Note for Vendor:* This step ensures that the SAML assertion is only generated for a user with a currently valid, verified session in the Bank's central Identity Provider.
3. **SAML Generation:** Once Ciam confirms the user's identity, the Bank Backend generates a standard **SAML 2.0 Response**.
 - The Backend signs this response using the Bank's private key (the counterpart to the public certificate uploaded to Auth0).
 - The NameID in the assertion matches the user's unique identifier required by Marstone.
4. **Auto-Submit Form:** The Backend returns a standard HTML response to the Native App containing a hidden <form> populated with the signed SAML data and a JavaScript command to automatically submit it.
5. **WebView Hand-off:** The Native App loads this HTML into the secure WebView.
6. **Bridge Execution:** The WebView executes the script and POSTs the signed SAML response to the specific **Auth0 Callback URL** for this connection (e.g., [https://\[vendor\].auth0.com/login/callback?connection=Bank-Mobile-Bridge](https://[vendor].auth0.com/login/callback?connection=Bank-Mobile-Bridge)).
7. **Session Establishment:** Auth0 receives the POST, validates the signature using the Bank's public certificate, and **establishes a valid Auth0 session cookie** in the WebView. Auth0 then redirects the browser to the Marstone Application URL.

Phase 2: Standard Marstone OIDC Flow (Silent)

This phase remains standard and requires no custom logic in the Marstone application.

8. **Application Load:** The Marstone web application loads in the WebView. It detects no local application session and initiates its standard OIDC Authorization Code flow (GET /authorize).
9. **Silent Authentication:** The request hits Auth0. Auth0 detects the valid session cookie

established in Step 7.

10. **Token Issuance:** Because a session exists, **Auth0 skips the login prompt** and immediately redirects back to the Marstone application with an Authorization Code.
 11. **Completion:** The Marstone application exchanges the code for tokens and logs the user in.
-

Key Takeaway for Architecture Review

- **Role of Ciam:** Ciam acts as the "Authority" verifying the user is valid before the process starts.
- **Role of Bank Backend:** Acts as the "Bridge," converting Ciam's API trust (Token) into Auth0's Browser trust (SAML).
- **Role of Auth0:** Trusts the Bank Backend's signature to create the session.